SECURITY REPORT · APT / DPRK

북한의 해킹 부대

온라인 게임부터 가상화폐까지

정찰총국 산하 사이버 공격 조직의 진화와 현황 — 위협 분석 및 대응 가이드

Dennis Kim / gameworker@gmail.com / https://github.com/gameworkerkim/

$6.75B+	86건	7,000명+	60%
누적 탈취 추정액	2025년 APT 공격 (국내)	추정 해커 인력	전 세계 가상화폐 해킹 점유

01 북한 해킹 조직 구조

북한의 사이버 공격은 개인이나 민간 단체의 활동이 아니다. **조선노동당 정찰총국(RGB, Reconnaissance General Bureau)** 직속으로 운영되는 국가 단위의 체계적 사이버 전력이다.

2009년 노동당 작전부, 35호실, 인민무력부 정찰국을 통합해 설립된 이 기관은 6개 국(局)으로 구성되며 핵심 해킹 부

대를 직접 지휘하고 있다.

> **국가 지원 해킹 조직의 의미**
>
> 이들은 단순 범죄 집단이 아니라 국가 예산과 군사 기술 지원을 받는다. 해킹으로 탈취한 자금은 핵무기·탄도미사일 개발 재원으로 전용된다는 사실이 유엔 안전보장이사회 보고서를 통해 거듭 확인됐다.

조직명	별칭	주요 임무	대표 공격
라자루스 (Lazarus)	Zinc / Hidden Cobra	금융 탈취, 인프라 파괴, 전방위 APT	소니픽처스, 업비트, 바이비트
블루노로프 (Bluenoroff)	라자루스 하위	금융기관·가상화폐 거래소 전문 금전 탈취	방글라데시 중앙은행, SWIFT 해킹
안다리엘 (Andariel)	Silent Chollima	랜섬웨어, 자격증명 탈취, 방산 해킹	업비트 공모, 방산업체 10여 곳 침투
김수키 (Kimsuky)	Thallium	정보 수집, 스피어피싱, 외교·안보 기밀	한수원 해킹, 외교라인 해킹
스카크러프트 (Scarcruft)	APT37	한국·일본·중동 민간/공공 부문 침투	태영호 스마트폰 해킹

※ 안랩 2025년 보고서: 북한 APT 공격 86건 — 중국(27건)·러시아(18건)를 압도

02 해킹의 역사 — 게임 오토부터 중앙은행까지

북한의 해킹 전략은 단계적으로 진화했다. 초창기에는 온라인 게임 오토 프로그램 판매로 외화를 벌었고, 이후 금융망 침투, 글로벌 랜섬웨어, 가상화폐 탈취로 점차 타깃과 수법이 정교화됐다.

2000년대 초반 온라인 게임 오토 프로그램 — 첫 번째 외화벌이

조선릉라도무역총회사·조선콤퓨터쎈터를 통해 리니지·메이플스토리·던전앤파이터용 오토 프로그램 제작·판매. 수익은 39호실 경유 통치자금 유입. 사설서버 운영자가 북한 해커로부터 해킹 프로그램 구입 후 2,380만 원 중국 계좌 송금 → 국보법 위반 구속.

2009 트로이 작전 (Operation Troy)

한국군·주한미군 타깃. 악성코드가 최소 4년간 정부·군 컴퓨터에 잠복해 군사 기밀 수집. 청와대 홈페이지 DDoS 공격 병행.

2014 소니픽처스 해킹 / 한수원 해킹

영화 '더 인터뷰' 보복으로 소니 내부망 파괴. FBI 북한 배후 공식 지목. 국내에서는 한국수력원자력 원전 도면 탈취.

2016 방글라데시 중앙은행 해킹 — $81M 탈취

SWIFT 시스템 해킹, 미국 연준에 허위 송금 지시. 필리핀 카지노 통해 세탁. 블루노로프 소행.

2017 워너크라이 랜섬웨어 [CRITICAL]

150개국 30만 대 감염. 영국 NHS 마비. NSA 유출 취약점 EternalBlue 활용. 미·영 정부 북한 공식 규탄.

2019 업비트 이더리움 해킹 — 580억 원 탈취

ETH 34만 2천 개 탈취. 5년 수사 끝에 라자루스·안다리엘 공모 확인. 현재 시가 약 1조 4,700억 원 상당.

2024 방산업체 총력전

라자루스·안다리엘·김수키 3개 조직 동시 투입. 83개 방산업체 공격, 10여 곳 침투 성공.

2025 바이비트 해킹 — $1.46B 탈취

개발자 PC 1대 감염으로 역대 최대 단일 사건 달성. 2025년 북한 탈취 총액 20억 달러 돌파.

03 업비트 해킹 — 가상화폐 타깃의 전환점

2019년 11월 업비트 해킹은 북한의 전략이 전통 금융에서 **가상자산 거래소**로 본격 전환한 분수령이다. 국제 제재로 전통 채널이 막히자 탈중앙·익명성의 가상화폐가 최적 대안으로 부상했다.

```
// 사건 개요
피해 규모: ETH 342,000개 (당시 580억 원 / 현재 약 1.4조 원)
발생 일시: 2019년 11월
공식 확인: 2024년 11월 (경찰청 국가수사본부)
배후 조직: 라자루스(Lazarus) + 안다리엘(Andariel) 공모
수사 협조: FBI 공조, 북한 IP주소·용어('헐한 일') 확인
```

▸ 탈취 후 자금 세탁 경로

[1] 북한 자체 교환소 활용 (57%)

북한 설계·운영 익명 교환소 3곳에서 ETH를 시세 대비 2.5% 싸게 BTC로 전환. 외부 KYC 없이 즉각 현금화.

[2] 13개국 51개 거래소 경유 세탁 (43%)

중국·미국·홍콩·스위스 등 전 세계 거래소 분산 활용. 출처 혼합으로 국제 추적 복잡화.

[3] 중국 OTC 브로커 및 지하 금융 네트워크

중국 유니온페이 카드 연계 법정화폐 전환. 삼합회 등 범죄 조직과 협력해 최종 현금화.

04 텔레그램과 커뮤니티를 활용한 침투 수법

텔레그램은 암호화 통신·익명성·봇 자동화 구조로 가상화폐 커뮤니티의 주요 소통 채널이 됐다. 북한은 이를 악성코드 유포·피해자 접촉의 핵심 통로로 활용하고 있다.

가짜 지갑 앱 유포

마이시리엄 UI를 복제한 '소모라(Somora)' 앱을 텔레그램 링크로 유포. 앱스토어 외부 배포로 보안 검증 우회.

투자 채널 위장

고수익 투자 제안 채널·DM으로 신뢰 형성 후 '전용 투자 플랫폼' 설치를 유도. 악성 앱 다운로드 권유.

줌 미팅 사칭 공격

텔레그램 지인 사칭 → Calendly 일정 → 가짜 Zoom 초대 → SDK 업데이트 스크립트 실행 유도. 1만 줄 공백으로 악성코드 은닉.

AI 딥페이크 신원 위조

AI 생성 가짜 얼굴·신분증으로 투자자·유명인 사칭. 화상 통화에서도 탐지 어려운 딥페이크 활용.

▸ 악성코드 기능 목록 (NimDoor 계열)

```
// 라자루스 악성코드 기능
키로깅: 키보드 입력 전체 기록 → 비밀번호·시드 구문 탈취
클립보드 감시: 복사된 지갑 주소를 해커 주소로 실시간 교체
브라우저 데이터: 저장된 인증정보·쿠키·세션 탈취
```

지갑 확장 프로그램: MetaMask 등 24개 이상 지갑 데이터 탈취
원격 제어: 웹캠·마이크 원격 조종, 파일 전송·삭제
텔레그램 데이터: 텔레그램 로컬 데이터 탈취 스크립트(tlgrm) 실행
지속성 유지: LaunchAgent 등록으로 재부팅 후에도 자동 실행

05 개발자 위장 침투 — 가장 정교한 사회공학 공격

2024~2025년의 가장 두드러진 전술은 **IT 개발자·엔지니어로 위장해 가상화폐 기업에 정식 취업**하는 방식이다. 체이널리시스 보고서에 따르면 2024년 한 해에만 12개 이상의 기업에 북한 요원이 합법적 직원으로 침투했다.

> **경계 보안의 무력화**
> 공격자가 합법적 내부 접근 권한을 보유할 때, 방화벽·네트워크 경계 보안은 효과가 없다. 이 전략은 업계 전반에 근본적인 신뢰 위기를 초래한다.

[1] 가짜 신원 구축
AI 생성 사진, 허위 경력, 유령 회사 이력 조합. LinkedIn·GitHub에 일정 기간 활동 이력 축적.

[2] 원격 채용 지원
블록체인 개발자·스마트컨트랙트 엔지니어 등 고수요 포지션 지원. 기술 면접 통과 수준의 실력 보유.

[3] 내부 시스템 정찰
합법적 직원으로 근무하며 인프라·보안 구조·프라이빗 키 관리 방식을 수개월에 걸쳐 파악.

[4] 실행 — 내부에서 공격 지원
자격증명 제공, 보안 시스템 비활성화, 사기 거래 승인 등 해킹 팀의 외부 공격을 내부에서 직접 보조.

▸ GitHub 위장 오픈소스 공격

```
// 공격 흐름 (VSCode 자동화 악용)
Step 1: GitHub에 정상 프로젝트로 위장한 악성 저장소 업로드
Step 2: 개발자가 클론 후 VSCode로 폴더 오픈
Step 3: .vscode/tasks.json이 악성 스크립트 자동 실행
Step 4: 악성코드 본체는 .woff2·.svg로 위장 → 보안 검사 우회
Step 5: 브라우저 인증정보 + 24개 이상 지갑 확장 데이터 탈취
// 대상 OS: Windows / macOS / Linux 전부
```

06 바이비트 해킹 — 역대 최대 규모 단일 사건

> *"Safe{Wallet} 개발자 1명의 MacBook이 감염된 지 17일 만에, 북한 라자루스는 단 하나의 노드로 15억 달러를 탈취했다."*
>
> — BlockEden 분석 보고서, 2026년 2월

사건 개요

2025년 2월 발생. 세계 3위 거래소 바이비트에서 약 15억 달러(2조 1,800억 원) 탈취. 역대 단일 사건 최대 피해.

침투 경로

Safe{Wallet} 개발자 PC 감염 → 다중 서명 지갑 서명 인프라에 백도어 삽입 → 멀티시그 승인 프로세스 조작.

세탁 속도

탈취 후 48시간 이내 2~3억 달러 세탁 완료. 한 달 내 ETH의 86.29%를 BTC로 전환. '48시간 세탁 산업화' 확인.

배후 확인

FBI 공식 발표: 라자루스 계열 트레이더트레이터(TraderTraitor) 지목. 과거 북한 네트워크 패턴·세탁 방식 일치.

업비트와 바이빗의 경우 사회 공학적인 해킹에 너무나 쉽게 당했다는 것이 문제이다.

07 자금 세탁 방법론과 추적 한계

개미떼 세탁 (Smurfing)

50만 달러 이하로 수천 번 분산 송금해 국제 감시망 무력화. 행동 패턴 중심의 대응 전략 필요.

크로스체인 브릿지·토네이도 캐시

서로 다른 블록체인 간 이동으로 추적 단절. OFAC 제재 대상 토네이도 캐시도 우회 사용 지속.

바이낸스 경유 세탁

ICIJ 탐사보도: 북한 수익금 약 9억 달러가 바이낸스 계좌 5개로 유입된 거래 기록 확인.

중국 지하 금융 네트워크

OTC 브로커, 삼합회, 마카오 카지노를 통해 가상화폐를 법정화폐로 전환. 중국 내 추적이 최대 장벽.

08 특이점 분석 — AI 고도화와 공격의 산업화

① 공격 정예화

해킹 건수 74% 감소, 탈취 총액 51% 증가. 더 적은 공격으로 더 큰 수익 — TRM Labs가 '탈취의 산업화'라 명명.

② 인간 취약점 공략

기술 취약점 → 사회공학으로 완전 전환. 코드보다 인간이 더 취약하다는 것을 실증. 위장 채용·스피어 피싱이 주력.

③ AI 도구 전면 도입

딥페이크 신원, 피싱 문서 자동화, 취약점 탐색 자동화, 웹캠·마이크 원격 감시. AI가 공격 전 과정에 통합됨.

④ 세계 최고 수준 인력

해커어스 대회 1~4위 독식, 코드셰프 2013~2020년 18회 우승. 15년 이상 집중 육성된 사이버 전사들.

09 개인·기업 대응 체크리스트

대응의 핵심 원칙

북한의 공격은 기술적 취약점보다 인간의 신뢰와 습관을 노린다. 기술적 보안 강화와 함께 사람·프로세스·공급망을 중심으로 한 보안 문화가 필수다.

▸ 기본 방어 수칙

텔레그램 DM 경계	하드웨어 지갑 분리	클립보드 해킹 대비
모르는 사람의 투자 제안·파일·링크 절대 금지. 지인 사칭 시 별도 채널로 신원 확인 필수.	대규모 자산은 콜드월렛 보관. 핫월렛에는 일상 거래용 소액만 유지.	지갑 주소 전송 직전 반드시 육안으로 전체 주소 비교 확인. 클리퍼 악성코드 탐지 솔루션 사용.
채용 제안 이메일 주의	**오픈소스 코드 검증**	**공급망 보안 감사**
과제 파일 실행 요청 즉각 거부. 공식 채널 통한 별도 신원 확인 필수.	.vscode/tasks.json, package.json 스크립트 수동 확인 후 실행. VSCode 자동 실행 차단 설정.	제3자 라이브러리·서비스 정기 점검. 외주 개발자 채용 시 백그라운드 체크 강화.

▸ 이중 인증(2FA) — 계정 탈취 최후 방어선

2FA 없는 계정은 열쇠 없는 금고와 같다

비밀번호가 탈취되더라도 2FA가 활성화된 계정은 공격자가 두 번째 인증을 통과하지 못하면 진입 불가다. 라자루스의 키로깅·피싱 공격으로 비밀번호가 유출되는 사례가 반복되는 만큼, 2FA는 선택이 아닌 필수다.

하드웨어 보안키 (FIDO2/U2F) — 최강

YubiKey 등 물리적 하드웨어 키. 피싱 사이트에 입력해도 도메인 불일치 시 인증 자체가 불가. 가장 높은 보안 수준. 거래소 및 고액 자산 계정에 권장.

TOTP 앱 (Google Authenticator / Authy)

30초마다 갱신되는 6자리 OTP. SMS보다 안전하며 오프라인 작동. 단, 스마트폰 분실·악성앱 감염 시 노출 가능. 반드시 백업 코드를 오프라인으로 보관.

SMS 2FA — 최소한의 보호 (비권장)

SIM 스와핑(유심 탈취) 공격에 취약. 북한 등 국가 수준 공격자는 통신사 해킹이나 SS7 프로토콜 취약점으로 SMS를 가로챌 수 있다. TOTP나 하드웨어 키로 반드시 교체.

이메일 2FA — 사용 금지

이메일 계정이 이미 피싱·스피어피싱의 주요 표적. 이메일 2FA는 이메일 계정이 뚫리는 순간 무력화된다. 어떠한 경우에도 이메일 2FA만으로 가상화폐 계정을 보호하지 말 것.

2FA 적용 우선 순위: 거래소 계정 > 이메일 계정 > 텔레그램/소셜미디어 계정 > 클라우드 스토리지 순으로 반드시 설정한다. 특히 거래소 API 키를 사용하는 경우 API 권한을 출금 불가·읽기 전용으로 제한하고, IP 화이트리스트를 병행 설정하는 것이 필수다.

PC방·공공 인터넷 환경 — 가상화폐 접속 절대 금지

PC방·공공 PC에서 가상화폐 거래 시 발생 가능한 위협

키로거(Keylogger) 설치 여부 확인 불가 — PC방 컴퓨터에는 수십~수백 명의 불특정 사용자가 접근한다. 악성코드나 키로거가 이미 설치돼 있어도 육안으로 확인할 방법이 없다.

브라우저 세션 잔류 — 로그아웃을 하더라도 브라우저 캐시·쿠키·자동완성 데이터에 인증 정보가 남아 다음 사용자에게 노출될 수 있다.

공용 Wi-Fi 중간자 공격(MITM) — 카페·도서관·공항 등 개방 네트워크는 동일 네트워크 상의 공격자가 트래픽을 가로채거나 가짜 AP(액세스 포인트)로 유도할 수 있다.

화면 엿보기(Shoulder Surfing) — 시드 구문·비밀번호 입력 시 주변인의 시선이나 CCTV에 그대로 노출될 수 있다.

낯선 환경에서 반드시 지켜야 할 수칙

- ✓ 가상화폐 거래소·지갑 접속은 반드시 본인 소유의 기기(스마트폰·노트북)로만 수행
- ✓ 불가피하게 공공 PC 사용 시 시드 구문·프라이빗 키·비밀번호는 절대 입력하지 않는다
- ✓ 공공 Wi-Fi 사용 시 VPN을 필수로 켠 후 접속 — 단, 신뢰할 수 있는 유료 VPN 서비스 한정
- ✓ 거래소 앱은 공식 앱스토어에서만 설치 — QR코드·링크를 통한 설치 절대 금지
- ✓ 2FA 인증번호는 화면 공유·방송 중에 절대 노출하지 않는다 (스트리머·유튜버 주의)
- ✗ PC방 사용 후 반드시 브라우저 전체 기록·쿠키·저장 비밀번호 삭제 (불충분한 임시 대응)
- ✗ 개인 핫스팟 없이 PC방 유선 LAN에 개인 지갑·거래소 접속 (네트워크 감시 노출 가능)
- ✗ '잠깐만 볼게요'식 타인의 기기에서 거래소 로그인 — 절대 금지

거래소·프로젝트 운영자 전용 체크리스트

- ✓ 핫월렛 자산 비율을 전체의 10% 이하로 제한, 나머지는 콜드 스토리지로 분리
- ✓ 멀티시그 지갑의 서명 인프라 자체 보안 점검 — 제3자 서비스 포함 (바이비트 교훈)
- ✓ 모든 관리자 계정에 FIDO2 하드웨어 키 기반 2FA 필수 적용
- ✓ 원격 직원 채용 시 딥페이크 가능성 고려한 추가 신원 확인 절차 도입
- ✓ 내부 직원 권한 접근 로그 실시간 모니터링 및 이상 행동 즉시 알림 설정
- ✓ 개발팀 PC 엔드포인트 보안 솔루션 배포 및 외부 소프트웨어 설치 제한

- ✗ 신뢰할 수 없는 소스의 SDK·라이브러리를 검증 없이 프로덕션 배포
- ✗ 대규모 출금 요청을 자동화 시스템 단독으로 처리 (인간 검증 단계 미포함)
- ✗ 북한 제재 관련 블록체인 주소 DB를 실시간 대조하지 않고 거래 승인

REF 출처 및 참고 자료

본 보고서는 다음 공식 발표 자료, 수사 결과, 보안 연구 보고서를 근거로 작성됐다.

▸ 정부 기관 및 수사 기관

[1] **경찰청 국가수사본부** — 업비트 해킹 사건 수사 결과 발표 (라자루스·안다리엘 공모 확인) (2024년 11월)
https://www.police.go.kr/www/news/press/2024/press2024111301.jsp

[2] **경찰청·방위사업청·국가정보원** — 국내 방산업체 사이버 공격 합동 특별점검 결과 발표 (2024년 4월)
https://www.boannews.com/media/view.asp?idx=129172

[3] **FBI (미국 연방수사국)** — TraderTraitor: North Korean Cyber Group Identified as Bybit Hack Perpetrator (2025년 2월)
https://www.fbi.gov/news/press-releases/fbi-identifies-north-korean-cyber-actors-responsible-for-bybit-hack

[4] **OFAC (미국 재무부 해외자산통제국)** — Sanctions Designations: Lazarus Group, Bluenoroff, Andariel (2019년 9월)
https://ofac.treasury.gov/recent-actions/20190913

[5] **유엔 안전보장이사회** — Final Report of Panel of Experts, S/2024/215 — 북한 사이버 탈취 활동 분석 (2024년)
https://www.undocs.org/S/2024/215

[6] **국가정보원·독일 연방헌법수호청 (BfV)** — 라자루스 사이버 위협 공동 보고서 (2024년)
https://www.nis.go.kr:4016/AF/1_7_3_1/view.do?seq=120

▸ 보안 기업 및 블록체인 분석 기관

[7] **Chainalysis** — Crypto Crime Report 2025 — 북한 연계 해킹 조직 가상자산 탈취 분석 (2025년)
https://www.chainalysis.com/blog/2025-crypto-crime-report/

[8] **Elliptic** — North Korea Crypto Theft: $2.02B in 2025 — 역대 최대 규모 보고 (2025년 10월)
https://www.elliptic.co/blog/north-korea-crypto-theft-2025

[9] **TRM Labs** — 바이비트 해킹 자금 추적 분석 및 TraderTraitor 귀속 보고서 (2025년 2~3월)
https://www.trmlabs.com/blog/trm-insights-bybit-hack

[10] **안랩 (AhnLab)** — 2025년 사이버 위협 동향 & 2026년 보안 전망 보고서 (2025년 11월)
https://www.ahnlab.com/ko/site/securityinfo/secunews/secuNewsView.do?seq=73792

[11] **Kaspersky (카스퍼스키)** — 라자루스 텔레그램 악성코드 유포 연구 보고서 — 소모라(Somora) 분석 (2020년 1월)
https://securelist.com/lazarus-on-the-hunt-for-big-game/97757/

[12] **SentinelOne —** NimDoor 맬웨어 분석 — macOS 타깃 북한 연계 백도어 (2025년 7월)
https://www.sentinelone.com/blog/nimdoor-north-korea-linked-backdoor/

[13] **BlockEden.xyz —** Lazarus Group Playbook: Inside North Korea's $6.75B Crypto Theft Operations (2026년 2월)
https://blockeden.xyz/ko/blog/2026/02/03/lazarus-group-playbook-north-korea-crypto-theft-6-75-billion/

▸ 언론 및 탐사보도

[14] **ICIJ (국제탐사보도언론인협회) —** 북한 해킹 수익금 바이낸스 경유 세탁 — 9억 달러 거래 기록 확인 (2025년 11월)
https://www.sedaily.com/NewsView/2H0HNUR6GO

[15] **자유아시아방송 (RFA) —** 바이비트 해킹 자금 세탁 추적 — TRM Labs 레드보드 소장 인터뷰 (2025년 3월)
https://www.rfa.org/korean/in-focus/2025/03/13/north-korea-bybit-hack-crypto-laundering/

[16] **시사저널 —** 김정은의 비밀무기 '북한 해커부대'의 실체 — 정찰총국 산하 조직 분석 (2024년 11월)
https://www.sisajournal.com/news/articleView.html?idxno=316144

[17] **SBS 뉴스 —** 가상화폐 앱으로 위장한 북한 악성코드 텔레그램 확산 보도 (2022년 12월)
https://news.sbs.co.kr/news/endPage.do?news_id=N1007009050

[18] **서울신문 —** 북한 지능형 해킹 대규모 공격 — AI로 무장한 전방위 사이버 위협 (2025년 11월)
https://www.seoul.co.kr/news/economy/industry/2025/11/30/20251130500108

[19] **헤럴드경제 —** 무차별 공격에서 '큰 거 한 방'으로 — 북한 가상자산 해킹 전략 변화 분석 (2025년 12월)
https://biz.heraldcorp.com/article/10640660

[20] **데일리시큐 —** 북한 라자루스 그룹 2025년 가상화폐 탈취 3조원 돌파 분석 (2025년 10월)
https://www.dailysecu.com/news/articleView.html?idxno=201211

본 보고서에 수록된 모든 수치·사건 내용은 위 공개 자료를 기반으로 하며, 수사 결과 미확정 사항은 현재 공개된 정보 범위 내에서 기술됐다.